

AA-00

Programme Charter and Architecture Overview

Why three portals, what each one is, and the fourteen invariants that bind them

30 August 2026 · Rev 1.0 — baseline

PORTALS	REPOSITORIES	INVARIANTS
Three	Five	Fourteen
NEW TABLES	WEEKS	RECURRING COST
36	Ten	Rs 0

This is the first document of thirteen. It states what we are building, why the shape is what it is, and the fourteen invariants that every other document in the set must obey. If a later document contradicts this one, this one is wrong and must be corrected here first, then regenerated. Nothing in this set is edited as prose.

0.1 WHAT THIS PROGRAMME IS

One sentence, then the honest version

Atavishaala today is a mobile app for farmers who buy seeds, fertiliser, pesticide and equipment, plus a Crop Advisor service that puts an agronomist on the phone within two hours. It is operated by hand. A founder-operated console curates the catalog, an operator moves orders through their states, and delivery is arranged over WhatsApp. That works for a pilot and stops working at roughly a hundred orders a week.

This programme replaces the hand-operation with three web portals, each for a different kind of organisation, all reading and writing through one backend. Internal staff get an admin portal. The product companies that supply the catalog get a supplier portal and become responsible for their own listings, stock, prices and dispatch. The delivery companies that move the goods get a fleet portal and become responsible for their own riders, acceptance of work, proof of delivery and cash remittance.

The honest version is that this is not a feature. It is a change of operating model. Today Atavishaala is a shop that happens to be online. After this programme it is a marketplace with two supply sides and a supervisory middle, and the middle is smaller than the organisation it supervises. Every design decision in the twelve documents that follow is downstream of that sentence.

WHAT CHANGES

Catalog authorship, dispatch responsibility, delivery execution and cash handling all move out of the founder console and into the hands of the organisations that actually do the work, under supervision rather than under instruction.

WHAT DOES NOT CHANGE

The mobile app contract. The farmer sees the same five-state order tracker, the same wallet, the same Advisor flow. Not one screen in the app is redesigned by this programme, and that constraint shaped the data model.

0.1.1 Why now rather than later

Three pressures arrive at the same time. The catalog cannot grow past a few hundred items while one person types them in, so supplier self-service is the only path to breadth. Delivery cannot reach a second district while one operator arranges riders in a WhatsApp group, so a fleet marketplace is the only path to coverage. And the founder console has accumulated enough privilege that a single compromised session is now a business-ending event, so a real permission model is the only responsible answer.

Doing these three separately would mean three migrations of the order lifecycle, because all three touch it. Doing them together means one migration, done carefully, with a rollback plan. That is the argument for one ten-week programme rather than three quarters of incremental work.

0.2 THE THREE PORTALS AND WHO SITS IN THEM

Four kinds of organisation, four token audiences, one backend

A portal is not a page in an app. It is a separate deployed front end, on its own hostname, serving one class of principal, consuming exactly one API namespace. That separation is the load-bearing decision of the whole programme, and section 0.4 gives the reasoning.

PORTAL	HOSTNAME	WHO SIGNS IN	WHAT THEY DO	SCR
Admin	admin.atavishaala.in	Atavishaala employees: ops, catalog, finance, partner and fleet managers, agronomists, auditors	Supervise everything. Moderate listings, resolve delivery exceptions, approve payouts, reconcile cash, answer Advisor requests, investigate customer issues.	41
Supplier	seller.atavishaala.in	Staff of a verified product company (a partner org)	Own their listings and stock, price their goods, accept and pack shipments, hand over to the rider, see their earnings and payouts, argue about returns.	26
Fleet	fleet.atavishaala.in	Staff and riders of a registered delivery company (a fleet org)	Take or decline offered delivery jobs, run riders and vehicles, define service areas and rates, capture proof of delivery, declare and remit collected cash.	24
Mobile app	existing app	Farmers and other buyers	Unchanged by this programme. Browse, order, pay, track, request Advisor help, review.	--

THE RIDER IS NOT A USER OF ATAVISHAALA

A rider signs into the fleet portal as an employee of a delivery company, not as an Atavishaala principal. Atavishaala never employs a rider, never pays a rider, and never holds a rider bank account. It pays the fleet org; the fleet pays the rider. This is a legal boundary as much as a technical one and it is why there is no rider role in the admin permission set.

0.2.1 The four actor classes

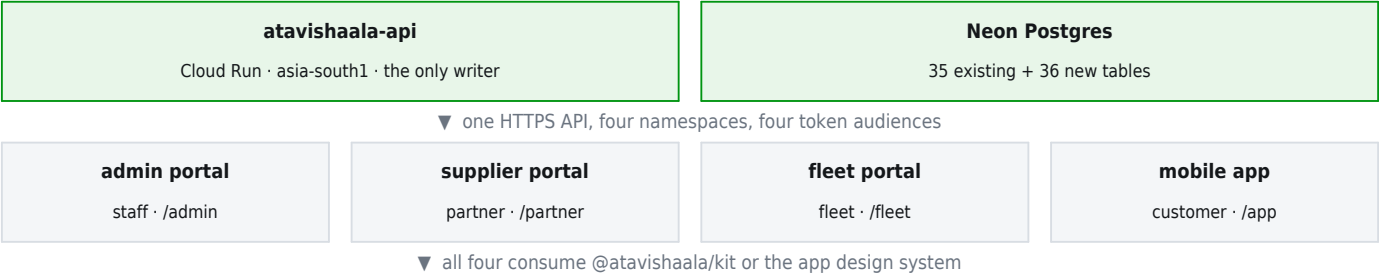
ACTOR	ENTITY	AUTH	AUD	SURFACE	TOTP	NOTES
customer	User	Mobile OTP (WhatsApp, SMS fallback)	atv_app	Mobile app	No	Farmers and other buyers. Existing. Unchanged.
staff	StaffUser	Email + Argon2id password + mandatory TOTP	atv_admin	Admin portal	Yes, always	Atavishaala employees: ops, catalog, support, finance, agronomists, admins.
partner	PartnerUser	Email + Argon2id password, TOTP for finance	atv_partner	Supplier portal	Conditional	Employees of a verified product company (partner_orgs).
fleet	FleetUser	Email or mobile + Argon2id, TOTP for finance	atv_fleet	Fleet portal	Conditional	Employees and riders of a verified delivery company (fleet_orgs).

Four actor classes means four disjoint identity tables, four token audiences and four login flows. It deliberately does not mean four user tables joined by a polymorphic type column. A staff user and a partner user share almost no columns, no lifecycle, no authentication factors and no authorisation model, and every system that has tried to unify them has ended up with a table of nullable columns and a permission check that forgets which kind of principal it is holding.

0.3 SYSTEM TOPOLOGY

Five repositories, six hostnames, one writer to the database

The backend stays a single modular monolith. It is the only process holding a database credential, the only process holding a third-party secret, and the only place a business rule that writes may live. The three portals are static bundles on a CDN that make authenticated HTTP calls. There is no server-side rendering, no portal-side database access, and no backend-for-frontend layer.



0.3.1 The five repositories

REPOSITORY	KIND	STACK	DEPLOY TARGET	OWNER	RESPONSIBILITY
atavishaala-api	Backend	Express 5 · TS · Prisma · Node 20	Google Cloud Run (asia-south1)	BE-1, BE-2	The only writer to Postgres. Modular monolith, 11 modules, 4 API namespaces. Publishes @atavishaala/contract on tag.
atavishaala-portal-kit	Shared package	React 18 · TS · Vite lib mode · Tailwind preset	GitHub Packages (private npm)	FE-1 owns, FE-2 reviews	Design system, session/auth hooks, permission gate, PII masking primitives, generated API client re-export. Ships @atavishaala/kit.
atavishaala-admin-portal	Front end	Vite · React 18 · TanStack Query · Router 6	Cloudflare Pages -> admin.atavishaala.in	FE-1	Internal staff console. 41 screens including the agronomist Advisor console. Consumes /api/v1/admin only.
atavishaala-supplier-portal	Front end	Vite · React 18 · TanStack Query · Router 6	Cloudflare Pages -> seller.atavishaala.in	FE-2	Product-company self-serve. 26 screens. Consumes /api/v1/partner only.
atavishaala-fleet-portal	Front end	Vite · React 18 · TanStack Query · Router 6	Cloudflare Pages -> fleet.atavishaala.in	FE-2	Delivery-company self-serve, mobile-first for riders. 24 screens. Consumes /api/v1/fleet only.

WHY FIVE AND NOT ONE MONOREPO

A monorepo would be technically cleaner and is what I would choose with eight engineers. With two front-end engineers and three organisations that must be able to deploy on different days, separate repos buy three things that matter more than tidiness: an accidental import across portal boundaries becomes impossible rather than merely discouraged, a supplier-portal deploy cannot break the admin portal, and CI stays under two minutes per repo on the free tier. AA-01 section 1.2 states the costs of this choice honestly, including the version-skew tax the shared kit introduces.

0.3.2 Hostnames and what terminates where

HOSTNAME	SERVES	INFRASTRUCTURE	AUDIENCE
api.atavishaala.in	Backend API	Cloud Run + Cloudflare proxy	all four audiences
admin.atavishaala.in	Admin portal	Cloudflare Pages	StaffUser only
seller.atavishaala.in	Supplier portal	Cloudflare Pages	PartnerUser only
fleet.atavishaala.in	Fleet portal	Cloudflare Pages	FleetUser only
www.atavishaala.in	Marketing + legal	Cloudflare Pages	public
cdn (res.cloudinary.com)	Media delivery	Cloudinary free	public, signed uploads

0.4 THE FOUR API NAMESPACES

Namespace equals audience, checked before any handler runs

NAMESPACE	REQUIRED AUDIENCE	PRINCIPAL	WHAT LIVES HERE
/api/v1/public	none	anonymous	Health, legal docs, pincode serviceability, OTP request.
/api/v1/app	atv_app	customer	The React Native app. Existing surface, frozen shape.
/api/v1/admin	atv_admin	staff	Admin portal. Widest permission surface, fully audited.
/api/v1/partner	atv_partner	partner	Supplier portal. Every query tenant-scoped to partner_org_id.
/api/v1/fleet	atv_fleet	fleet	Fleet portal. Every query tenant-scoped to fleet_org_id.

The rule is mechanical and it is invariant I-02. A token minted for one audience is rejected on every other namespace. The check is a router-level middleware called immediately after JWT verification and before any handler, so no handler can forget it. A staff token presented on the partner namespace does not return a permission error; it returns 401 with ACTOR_MISMATCH, because a permission error would leak that the route exists.

The practical value of this is not defence against a stolen token, which the audience claim handles anyway. It is that it makes an entire class of design mistake impossible. Nobody can write one endpoint that serves both an admin and a supplier with a conditional inside, which is how multi-tenant systems leak. If admin and supplier both need to see a shipment, that is two endpoints with two different response shapes, and the supplier one is tenant-scoped by construction.

DUPLICATION WE ACCEPT

Roughly a fifth of the endpoint surface is a near-duplicate across namespaces. GET /admin/shipments/:id and GET /partner/shipments/:id read the same row and return different fields. We accept the duplication because the alternative is a single endpoint whose response shape depends on who is asking, and that is the shape of every tenant-leak postmortem.

DUPLICATION WE DO NOT ACCEPT

The domain logic underneath is shared. Both endpoints call the same module service and the same assertTransition. Only the serialiser and the scope differ. A rule that exists twice is a rule that will disagree with itself within a quarter.

0.4.1 Tenant scope is never in the request

For the partner and fleet namespaces, the tenant identifier is read from the verified token claim and from nowhere else. A request body or query string carrying partner_org_id or fleet_org_id is rejected with 400 SCOPE_IN_REQUEST rather than ignored, because a client that sends it has misunderstood the contract and silence would let that misunderstanding ship.

Below the handler, the only permitted way to reach the database in those two namespaces is scoped(prisma, principal), which returns a Prisma client with the tenant filter already applied. A direct prisma import inside a partner or fleet route file fails lint. This is invariant I-03 and it is the single most important line of defence in the system, because every other tenancy bug is a variation of a forgotten where clause.

0.5 THE FOURTEEN INVARIANTS

The rules that outrank convenience, deadlines and preference

An invariant is a statement that is true of the system at every commit, enforced by something other than good intentions. Each one below names its enforcement mechanism, because an invariant without a mechanism is a wish. If a task cannot be completed without breaking one of these, the task is wrong, not the invariant. Changing one requires changing this document first.

ID	INVARIANT	THE RULE	HOW IT IS ENFORCED
I-01	One backend, three thin clients	No portal holds a database credential, a third-party API secret, or a business rule that writes. Every mutation is an HTTP call to atavishaala-api.	A portal repo containing DATABASE_URL, a Prisma import, or a Cloudinary secret fails CI.
I-02	Namespace equals audience	A token minted for one audience is rejected on every other namespace. requireActor() runs immediately after JWT verification and before any handler.	Contract fixture sweep: every non-public route asserts 401 for the three wrong audiences.
I-03	Tenant scope comes from the token	partner_org_id and fleet_org_id are read from the verified token claim only. A request body or query string that carries either is rejected with 400 SCOPE_IN_REQUEST.	ESLint rule aa/no-tenant-in-input plus a repo-layer scoped() wrapper that is the only permitted entry point in partner and fleet namespaces.
I-04	Money is integer paise on an append-only ledger	Every monetary column is BIGINT and named *_paise. No FLOAT, no DECIMAL, no rupees. wallet_ledger, partner_payouts and fleet_payouts rows are never UPDATED or DELETED.	A Postgres rule raises on UPDATE/DELETE against the three ledger tables. A migration test greps the schema for FLOAT/DOUBLE/DECIMAL/NUMERIC on any *_paise column.
I-05	Every state change goes through assertTransition	orders, shipments, delivery_jobs, advisory_requests, partner_kyc, fleet_kyc, payout_runs and cod_remittances each have a transition table. Direct status writes are forbidden.	The status column has no setter outside the module service; an ESLint rule forbids { status: } inside any prisma.*.update call outside */fsm.ts.

ID	INVARIANT	THE RULE	HOW IT IS ENFORCED
I-06	Admin surfaces show the last four characters only	No phone, GSTIN, PAN, Aadhaar, bank account, IFSC, vehicle registration or driving licence is rendered beyond its last four characters in the admin portal. There is no reveal affordance and no role, including SUPER_ADMIN, that unmask.	There is deliberately no <code>pii.read.raw</code> permission in the Permission type union. A Prisma client extension masks unconditionally at the ORM boundary. Five ESLint rules and a pre-commit grep for ten consecutive digits.
I-07	Delivery address release is job-scoped, window-scoped and logged	A fleet principal sees a customer address only via <code>GET /fleet/jobs/:id/manifest</code> , only while the job is <code>ACCEPTED..OUT_FOR_DELIVERY</code> , only inside the delivery window, and every read appends a <code>pii_disclosures</code> row.	The manifest handler is the single code path that calls <code>unmaskAddress()</code> ; it is wrapped by <code>discloseOrThrow()</code> which writes the register row inside the same transaction.
I-08	Every admin write is audited with a before/after diff	Any request to <code>/api/v1/admin</code> with a method other than <code>GET</code> writes an <code>audit_log</code> row carrying actor, permission used, target, and a JSON diff. Audit rows are masked by the same extension.	Audit is an Express middleware on the admin router, not a per-handler call, so a new endpoint cannot forget it. A test asserts row count grows by one per mutating fixture.
I-09	Staff authentication requires TOTP; finance actions re-prompt	A <code>StaffUser</code> cannot complete login without a registered TOTP factor. Refund approval, payout release and permission changes require a fresh TOTP within the last 5 minutes.	<code>staff_users.totp_enrolled_at NOT NULL</code> is enforced before the session is issued. <code>requireFreshFactor(300)</code> guards the twenty-four mutating step-up routes. Four GET routes share a step-up permission and are not re-challenged, because the gate is applied on the mutation and not on the read.
I-10	No portal stores a token in web storage	Access tokens live in memory only; refresh tokens live in a <code>Secure, HttpOnly, SameSite=Strict, host-only</code> cookie. Every portal ships a CSP with no <code>unsafe-inline</code> and no wildcard <code>connect-src</code> .	grep for <code>localStorage sessionStorage</code> in the three portal repos fails CI. A Playwright check asserts the CSP header on each deployed host.

ID	INVARIANT	THE RULE	HOW IT IS ENFORCED
I-11	Customer order status is derived, never written	orders.status is a generated projection of its shipments, produced by reduceOrderStatus(). No endpoint in any namespace writes orders.status directly.	The column is maintained only by orders/fsm.ts::recomputeOrder(); a unit table drives all 28 shipment-state combinations to an expected order status.
I-12	Idempotency keys on money and on job offers	Every POST that moves money, accepts an offer, or releases a payout requires an Idempotency-Key header. Replays return the first response, byte for byte.	A shared idempotency_keys table with a unique index on (actor_id, endpoint, key); the middleware is applied by route metadata, and a contract test replays every such fixture.
I-13	The kit is versioned and pinned exactly	Portals depend on @atavishaala/kit and @atavishaala/contract at exact versions. No caret, no tilde, no workspace link in a portal repo.	A CI step parses each portal package.json and fails on a range specifier for either package.
I-14	Zero rupees per month recurring	Three additional front ends, one more npm registry and three more hostnames add nothing to the monthly bill. Any new paid dependency requires a written waiver naming the amount, the trigger and the fallback.	The AA-09 budget ledger is reviewed at the Friday gate; UptimeRobot and the free-tier threshold alerts are the tripwires.

THE ONE THAT WILL BE ARGUED WITH

I-06, last four characters only, with no reveal affordance and no permission that grants plaintext, will be argued with by whoever is on support at three in the afternoon of a bad day. The answer is no, and the reason is that a reveal button converts a database breach into a per-session breach and nothing more, while its absence converts a database breach into ciphertext. Support workflows that need to reach a customer use a templated send, not a phone number on a screen. AA-08 section 8.4 works through the four support scenarios that people raise.

0.6 THE STRUCTURAL CHANGE: THE SHIPMENT SPLIT

Why an order can no longer own a single status column

Today an order has one status and one delivery. That is coherent while one house catalog ships from one place. It stops being coherent the moment two different product companies each own part of the same basket, because the two parts are picked at different times, by different people, and handed to different riders. A single status column would have to be a lie about one of them.

The change is this. An order gains one or more shipments, one per supplier per order. Each shipment holds its own line items and its own state machine, and each shipment has exactly one delivery job. The order status becomes a projection computed from its shipments by a pure function, and no code path writes it.



0.6.1 How the order status is reduced

reduceOrderStatus takes the multiset of shipment states and returns exactly one order status by walking the rules below in order and stopping at the first match. It is a pure function with no database access, which is why it can be tested exhaustively rather than sampled.

#	IF THE SHIPMENTS ARE	THE ORDER STATUS IS
1	All shipments CANCELLED	CANCELLED
2	All shipments DELIVERED	DELIVERED
3	All shipments terminal, mix of DELIVERED and RETURNED/RTO_DELIVERED	PARTIALLY_DELIVERED
4	All shipments RETURNED or RTO_DELIVERED	RETURNED
5	Any shipment in RETURN_REQUESTED..RETURN_PICKED	RETURN_IN_PROGRESS
6	Any shipment OUT_FOR_DELIVERY or FAILED_ATTEMPT	OUT_FOR_DELIVERY
7	Any shipment HANDED_OVER, IN_TRANSIT or RTO_INITIATED	DISPATCHED
8	Any shipment PACKING or READY_FOR_PICKUP	PACKED
9	Any shipment AWAITING_ACCEPTANCE or ACCEPTED	CONFIRMED
10	Payment not captured and not COD-confirmed	PENDING_PAYMENT

WHY THE APP DOES NOT CHANGE

The app has always read the tracker from order_events, not from the status column. The events it cares about are still emitted, in the same order, with the same five customer-facing labels. A single-supplier order behaves identically to today because it has exactly one shipment.

WHAT THE APP GAINS LATER

A multi-supplier order can show two parcels arriving on different days, which is what the customer actually experiences. That is a mobile change we choose to defer; the backend is ready for it from week four onward.

THIS IS THE RISKIEST CHANGE IN THE PROGRAMME

Migration M4 backfills one shipment per existing order and rewrites the status relationship on live data. It gets a whole week, three rehearsals on a restored database branch, a fifteen-minute read-only window, a zero-row verification diff as the go condition, the pre-migration value retained in orders.legacy_status for two releases, and a written rollback runbook. Risk R-01 tracks it and AA-03 section 3.11 is the procedure.

0.7 THE DELIVERY MARKETPLACE IN ONE PAGE

Broadcast, first accept wins, three waves, then a human

When a shipment becomes ready for pickup, its delivery job is offered to the delivery companies whose service area covers the destination pincode and whose licences cover the goods. The offer is a broadcast, not an assignment. The first fleet to accept gets the job; everyone else sees it disappear. Acceptance is a single-winner operation guarded by an idempotency key and a conditional update, so two simultaneous accepts cannot both succeed.

If nobody accepts, the offer expires and re-broadcasts in a wider wave. After the third wave the job becomes UNASSIGNED and appears on the admin exception board, where a human assigns it, usually to the internal ATV-SELF fleet. Nothing silently stalls; escalation always terminates at a person.

WAVE	WHO IS OFFERED	TTL	ORDERING WITHIN THE WAVE	ON EXPIRY
1	Fleets whose service area covers the pincode at tier 1 and whose licences match	600 s	Least recently offered first, so work spreads rather than concentrating	Wave 2
2	Tier 1 and tier 2 fleets for the pincode, including neighbouring-area coverage	600 s	Least recently offered first	Wave 3
3	Every eligible fleet in the district plus the internal ATV-SELF fleet	900 s	Least recently offered first	UNASSIGNED
--	Nobody. The job is on the admin exception board awaiting manual assignment	none	A named ops person decides	Stays until assigned

WHY BROADCAST RATHER THAN A DISPATCH ALGORITHM

A scoring model that picks the best fleet needs data we do not have yet: real acceptance rates, real transit times, real failure rates per area. Broadcast needs none of that and it produces exactly the data a scoring model would require. We ship the mechanism that works from day one and earns its own inputs, and revisit allocation in Phase 2 once ten weeks of offer history exists. Cheap and honest beats clever and unfounded.

0.8 MONEY, AND WHY IT IS BORING ON PURPOSE

Integer paise, append-only ledgers, compensating entries

Three organisations are now owed money by Atavishaala: the customer for refunds, the supplier for goods, and the fleet for delivery. A fourth flow runs the other way, because cash collected on delivery belongs to Atavishaala and sits in a fleet safe until it is remitted. Getting this wrong is not a bug, it is a dispute, and disputes are settled by records rather than by argument.

So the money model is deliberately unexciting. Every amount is an integer in paise, in a BIGINT column whose name ends in _paise. There is no FLOAT, no DECIMAL and no rupee anywhere in the schema, and a migration test greps the schema to keep it that way. Balances are never stored; they are computed by summing an append-only ledger. A Postgres rule raises on UPDATE and DELETE against all three ledger tables, so a correction has to be a new signed row that explains itself.

LEDGER	WHOSE BALANCE	CREDITS ARE	DEBITS ARE	SETTLED BY
wallet_ledger	A customer	Refunds, referral credit, money added	Order payments made from wallet	Never paid out in cash
partner_ledger	A product company	Goods value on a delivered shipment, less commission	Return clawbacks, penalties, adjustments	payout_runs, bank transfer
fleet_ledger	A delivery company	Base plus distance plus COD handling per delivery	Failed-attempt and RTO fees, COD outstanding	payout_runs, bank transfer

THE WALLET IS CLOSED-LOOP AND STAYS THAT WAY

Money can enter the wallet and can be spent on Atavishaala orders. It can never be withdrawn to a bank account. Allowing cash-out would make Atavishaala a prepaid payment instrument issuer requiring RBI authorisation. There is no cash-out endpoint, and a contract test asserts that no such route exists.

CASH ON DELIVERY IS A LIABILITY, NOT REVENUE

Cash a rider collects is Atavishaala money held by a third party. It is tracked per fleet per day in cod_remittances with its own state machine. A fleet whose ledger balance goes negative is automatically blocked from receiving offers, and variance above two per cent moves it to prepaid-only.

0.9 PERSONAL DATA: THE POSTURE IN ONE PAGE

Last four characters only, and one narrow logged exception

Atavishaala holds farmer phone numbers, addresses and coordinates, plus company GSTINs, PANs, licence numbers and bank accounts. Three new portals means three new populations of people who could look at that data, two of which are not employees. The posture is therefore restrictive by construction rather than by policy.

Every sensitive field is stored in three columns: the ciphertext under AES-256-GCM, the last four characters in clear for display, and an HMAC index for exact-match lookup. Search works by hashing the query and comparing indexes, so an operator can find a customer by their full phone number without the system ever showing one. A Prisma extension strips the cipher column unconditionally, which means an endpoint cannot leak it by forgetting to select carefully.

FIELD	COLUMN	STORAGE	ADMIN SEES	PARTNER SEES	FLEET SEES
Customer mobile	users.phone	cipher + last4 + HMAC index	last 4 only	never	never
Customer name	user_profiles.full_name	plaintext (not a masked field)	full	first name only	first name only, on the manifest
Delivery address	addresses.*	line1/line2 cipher; locality, city, pincode plaintext	locality + city + pincode	locality + pincode	full, job-scoped and logged
Delivery coordinates	addresses.geo_lat/lng	cipher, 3-decimal rounded on read	never	never	full, job-scoped and logged
Delivery OTP	delivery_jobs.otp_hash	bcrypt hash only, digits never stored	never	never	never (entered, not read)
Login OTP	otp_challenges.code_hash	bcrypt hash only	never	never	never
Payment reference	payments.gateway_ref	cipher + last4	last 4 only	never	never
Partner GSTIN / PAN	partner_orgs.*	cipher + last4 + HMAC index	last 4 only	own, last 4 only	never
Bank account / IFSC	partner_bank_accounts, fleet_bank_accounts	cipher + last4	last 4 only	own, last 4 only	own, last 4 only
Payout UTR	payout_runs.utr_reference	cipher + last4	last 4 only	last 4 only	last 4 only
Rider licence number	riders.dl_*	cipher + last4 + HMAC index	last 4 only	never	own riders, last 4 only
Vehicle registration	vehicles.reg_*	cipher + last4 + HMAC index	last 4 only	never	own, last 4 only
KYC document image	Cloudinary private folder	signed URL, 5-minute expiry	view only, no download, logged	own uploads	own uploads
Staff / partner / fleet email	staff_users, partner_users, fleet_users	plaintext	full (business contact, not customer PII)	own org	own org

THE ONE EXCEPTION, AND WHY IT IS SAFE ENOUGH

A rider cannot deliver to a masked address. So GET /fleet/jobs/:id/manifest returns the full delivery address, and only that. It is gated on the job being accepted and not yet closed, gated on a four-hour window from acceptance, and every single read writes a row into pii_disclosures inside the same transaction as the read, naming the principal, the fleet, the job and the fields released. The customer phone number is never released at all; a rider who needs to reach the customer triggers a WhatsApp template send. The gap this leaves is a masked voice call, which no free provider offers in India, and it is recorded as an open paid gap rather than quietly ignored.

0.10 SCOPE

What is in, what is out, and what is deliberately deferred

IN SCOPE FOR THESE TEN WEEKS	EXPLICITLY OUT OF SCOPE
Three portals, five repositories, one shared kit. Staff identity with mandatory TOTP and 56 admin permissions. Partner org onboarding, KYC review, rate cards, catalog ownership and moderation. The shipment split and the derived order status. Fleet org onboarding, service areas, riders, vehicles. Offer allocation, delivery execution, proof of delivery. Partner and fleet settlement, payout runs, COD reconciliation. Returns, RTO and the clawback arithmetic. The agronomist Advisor console inside the admin portal. Audit log with before and after diffs on every mutation. The PII disclosure register. A single-district pilot with three suppliers and two delivery companies.	A native rider app. The fleet portal is mobile web, and that is a deliberate cost saving. Any change to the customer mobile app beyond what the split requires, which is nothing. Real-time rider GPS tracking on a map for the customer. Deferred to Phase 2. A dispatch scoring algorithm. Broadcast first, score later with real data. Masked click-to-call. Named as a paid gap, not built. Automated GST invoice generation per supplier. Manual for the pilot. A supplier-facing advertising or promotion product. Multi-currency, multi-country or multi-language admin. Admin is English only. Warehouse or inventory-location modelling. Stock is a number per supplier per variant. Wallet cash-out, which is prohibited outright rather than deferred. A public API for third parties. Replacing Razorpay or adding a second payment gateway.

0.11 THE TEAM, THE SHAPE OF THE TEN WEEKS, AND THE HONEST CAVEAT

Five engineers, one of whom is new to the programme

DEV	ROLE	MODULES OR SURFACES	WHAT THEY OWN
BE-1	Backend — platform	backoffice, partners, catalog, identity, platform	Owns the 88-permission matrix, the masking extension, the audit middleware, the moderation pipeline and partner settlement.
BE-2	Backend — fulfilment	orders, fleet, money, advisor	Owns the shipment split, both FSMs, the offer allocator, POD validation, COD reconciliation and fleet payouts. The critical path.
FE-1	Front end — admin + kit	atavishaala-portal-kit, atavishaala-admin-portal	Owns the shared kit first, then 41 admin screens including the Advisor console.
FE-2	Front end — partner + fleet	atavishaala-supplier-portal, atavishaala-fleet-portal	26 supplier screens then 24 fleet screens. Reuses the kit; contributes back, never forks.
MOB-1	Mobile — unaffected	atavishaala-api /app namespace consumer	Continues app work. Touched only by the order-tracker change in Week 4.

THE TEAM GROWS BY ONE, AND I AM SAYING SO PLAINLY

The existing plan of record has four engineers: MOB-1, BE-1, BE-2 and FE-1. Three portals with 91 screens between them cannot be built by one front-end engineer in ten weeks, so this plan adds FE-2 and assigns them the supplier and fleet portals. If FE-2 does not exist, the programme is not ten weeks; it is fifteen, and the ordered cut list in AA-10 section 10.7 is the mechanism for deciding what falls out rather than discovering it in week nine. Risk R-12 states this at high probability.

WK	THEME	WHAT IS TRUE AT THE END OF THE WEEK
W1	Foundations and identity	Five repos exist, CI green on all five, staff login with TOTP works end to end, the kit publishes its first version.
W2	Permissions, audit and the admin shell	The 88 permissions are seeded and enforced; every admin mutation is audited; the admin shell renders 12 read-only screens against real data.
W3	Partner tenancy and the moderation pipeline	A product company can be invited, submit KYC, be verified, draft a product and submit it; a catalog manager can approve it and it appears in the app.
W4	The shipment split	Orders split into shipments per supplier; orders.status is derived; the app tracker still reads correctly; M4 is proven on a restored snapshot.
W5	Offer allocation and the fleet marketplace	A ready shipment broadcasts an offer; a delivery company accepts it, attaches a rider and a vehicle; unaccepted jobs escalate through three waves onto the admin board.
W6	Delivery execution, proof of delivery and disclosure	A rider scans pickup, opens the manifest (logged), delivers with OTP inside the geofence, and the order shows DELIVERED in the app. Failed attempts and RTO both work.
W7	Settlement and cash on delivery	Payout accrual, weekly run assembly, lock, release with UTR capture; COD declaration and reconciliation; a synthetic week reconciled to the paisa.
W8	Returns, RTO and the Advisor console	The full return and RTO loop with compensating ledger entries, and agronomists working the advisory queue from the admin portal within the business-hours SLA.
W9	Hardening, contract sweep and the free-tier audit	Twelve CI gates green on five repos, the PII sweep clean, rate limits and CSP in place, eight free-tier thresholds configured and proven to fire.
W10	Pilot, runbooks and cutover	Two real product companies and one real delivery company transact end to end. Eleven runbooks written and rehearsed. Go or no-go decided on evidence.

0.12 THE FIVE RISKS WORTH A MANAGER READING

The full register of twelve is AA-10 section 10.6

ID	RISK	P	I	OWNER	TRIGGER TO WATCH FOR	RESPONSE
R-01	The M4 shipment backfill corrupts live order history	M	H	BE-2	Any mismatch between derived and stored status on the snapshot rehearsal	Rehearse on a restored Neon branch three times. Ship M4 behind a read-only window of 15 minutes. Keep the pre-migration status in orders.legacy_status for two releases.
R-02	No third-party fleet onboards in time for the pilot	H	H	You	Fewer than two fleet orgs at KYC_VERIFIED by end of W8	The ATV-SELF internal fleet org seeded in M5 is the fallback: staff deliver, the portal is used by staff, and the product is still complete. Do not delay go-live for this.
R-04	A rider needs the customer phone and the masked number blocks delivery	H	M	BE-1	Any support ticket where a delivery failed because the rider could not call	This is a known, accepted gap. MVP answer: a time-boxed reveal on the manifest that logs to pii_disclosures. Named upgrade: an Exotel or Kaleyra click-to-call bridge at roughly ₹0.60 per minute, requiring a written budget waiver against I-14.
R-08	A partner disputes a settlement figure and there is no evidence trail	M	H	BE-2	Any dispute that cannot be answered from partner_ledger alone	Append-only ledger plus an immutable pricing_snapshot per order line plus the effective-dated rate card. Never edit a payout line; post a compensating entry.
R-12	Ten weeks with four engineers is optimistic	H	M	You	Any Friday gate missed two weeks running	The AA-10 cut list is ordered and pre-agreed. C-1 to C-4 recover 11 dev-days without touching the core loop; the whole list recovers 20, which is one week of team capacity and no more. Below the line, nothing is cuttable.

P is probability and I is impact, each low, medium or high. The register is reviewed at the Friday demo gate, and a risk whose trigger has fired is either mitigated that week or converted into a cut. A risk that has been open and unchanged for three weeks is escalated as a decision rather than left as a worry.

THE THING MOST LIKELY TO ACTUALLY HURT US

Not the migration, which is scary but rehearsable. It is R-02: no third-party delivery company signs up in time, and the fleet portal has no users. The mitigation is that ATV-SELF, an internal fleet org, is seeded by migration M5 and is a first-class tenant in every flow. If no external fleet ever onboards, the system still works end to end with Atavishaala as its own delivery company, and the portal simply waits. Building the marketplace mechanism costs the same either way; building it only for an external party who may not arrive would have been the mistake.

0.13 THE COST LINE

Three more front ends, three more hostnames, zero more rupees

The constraint on this programme is the same constraint as on everything before it: no new recurring spend. That is invariant I-14 and it is met. Cloudflare Pages hosts five sites on one free account. GitHub Packages hosts the private kit inside the existing free allowance. Three subdomains on an owned domain cost nothing. Cloud Run scales to zero and the added portal traffic is negligible against the always-free tier.

RECURRING COST

Rs 0 / month

AMORTISED TOTAL

Rs 67 / month

NEW PAID SERVICES

None

The full ledger, with the alert threshold that fires before each free tier is exhausted and the pre-agreed degradation for each, is AA-09 sections 9.2 and 9.3. What matters here is the honest part: five things this programme wants cannot be done for nothing.

WHAT WE CANNOT DO FREE	WHY NOT	THE MANUAL WORKAROUND WE SHIP INSTEAD	THE PAID FIX
Masked click-to-call between rider and customer	No free provider offers a call bridge with number masking in India.	Time-boxed address reveal on the manifest, logged in pii_disclosures. Customer contact happens through a WhatsApp template send triggered by the rider, not a phone call.	Exotel or Kaleyra number masking, roughly ₹0.60/minute plus a ₹1 500/month platform fee.
Automated bank-account verification (penny drop)	Razorpay penny-drop and similar APIs are billed per verification.	A staff member transfers ₹1 by UPI and matches the holder name, then sets verified_at. Two suppliers and one fleet is roughly ten minutes of work per week.	Cashfree or Razorpay account validation, roughly ₹3 per verification.
Real-time rider GPS tracking on a map for the customer	Continuous location ingest is not free at any meaningful volume, and Maps tiles are billed.	Status milestones only: HANDED_OVER, IN_TRANSIT, OUT_FOR_DELIVERY. The POD captures a single geo point, which is all the geofence needs.	Google Maps Platform beyond the \$200 monthly credit, plus a location ingest path.
SMS delivery notifications at scale	Transactional SMS is billed per message and DLT registration is required.	WhatsApp template messages first, FCM push second, SMS only for OTP fallback.	2Factor.in or MSG91 at roughly ₹0.18 per transactional SMS plus DLT fees.
A hosted BI or reporting layer over the portal data	Metabase, Looker Studio against Postgres and similar all cost money or CPU we do not have.	Eleven fixed dashboard tiles computed by one SQL query, cached 30 s at the edge, plus masked CSV export for anything deeper.	Metabase Cloud from roughly \$85/month, or a small always-on VM.

HOW TO READ THAT TABLE

None of those five is a blocker. Each has a workaround that a person can execute, and each names the real price of removing the workaround. That is the format for every future request to spend money on this system: what breaks without it, what a human does instead, and what it costs to stop doing that.

0.14 THE DOCUMENT SET AND HOW TO READ IT

Thirteen documents, one fact base, no prose edits

ID	TITLE	WHAT IT ANSWERS	READ IT IF
AA-00	Programme Charter & Architecture Overview	Why three portals, what each one is, and the fourteen invariants that bind them	You are reading it. Everyone reads AA-00 first.
AA-01	Repository Topology, CI/CD & the Shared Portal Kit	Five repositories, their boundaries, pipelines, and the versioned kit between them	You are setting up a repository, a pipeline, or the shared kit.
AA-02	Backend Extension: Modules, Namespaces & Tenancy	Eleven modules, four API namespaces, and how tenant scope is made unforgeable	You are writing backend code in any namespace.
AA-03	Data Model & Migration Plan	Thirty-six new tables, the shipment split, and eight ordered migrations	You are writing a migration or a query.
AA-04	API Contract Reference	Every admin, partner and fleet endpoint at freeze, with scope and idempotency	You are calling the API from any portal.
AA-05	Admin Portal Specification	Forty-one screens for internal staff, plus the agronomist Advisor console	You are building or reviewing an admin screen.
AA-06	Supplier Portal Specification	Twenty-six screens for product companies: catalog, shipments, returns, payouts	You are building the supplier portal or onboarding a product company.
AA-07	Fleet Portal Specification	Twenty-four screens for delivery companies: offers, riders, POD, COD remittance	You are building the fleet portal or onboarding a delivery company.
AA-08	Identity, Permissions, PII & Security Charter	Four actor classes, eighty-eight permissions, and the last-four-only disclosure regime	You are touching authentication, permissions, personal data or logs.
AA-09	Operations, Free-Tier Budget & Runbook	The zero-rupee ledger for three more front ends, alert thresholds, and eleven runbooks	You are on call, or you are asked what this costs to run.
AA-10	Manager Strategic Roadmap	Ten weeks, four engineers, the Gantt, the risk register and the ordered cut list	You are deciding scope, sequence or what to cut.
AA-11	Team Execution Handbook	One hundred and thirty numbered tasks with owners, steps and checkable outputs	You are an engineer starting a week of work. This is your task list.
AA-12	Management Summary	The programme in plain language, for readers who will not open the other twelve	You have fifteen minutes and will not open the other twelve.

THE FACT BASE RULE, WHICH IS NOT OPTIONAL

All thirteen documents are generated from one Python module, `aa_facts.py`, which holds every identifier, count, price, permission, endpoint, screen, table, invariant, risk and task in the programme. Nothing in a PDF is typed by hand. When a number changes, the fact base changes and all thirteen are regenerated. Editing a sentence in one PDF to fix an inconsistency is the one thing you must not do, because it puts the set back into the state this pattern exists to prevent.

0.15 DECISION LOG

What was chosen, what was rejected, and why

A decision without its rejected alternative is not a decision, it is an assumption that nobody has noticed yet. Each row below records the choice, the serious alternative, and the reason the alternative lost. If a reason turns out to be wrong, the row is the place to reopen the argument.

#	DECISION	THE SERIOUS ALTERNATIVE	WHY THE ALTERNATIVE LOST
D1	Three separate portal repositories plus one shared kit repository	One monorepo with three apps and a packages directory	Two front-end engineers and three organisations deploying independently. Separate repos make a cross-portal import impossible rather than discouraged, keep each CI run under two minutes on the free tier, and stop a supplier deploy from breaking admin. The cost is version skew on the kit, which I-13 handles with exact pinning.
D2	Delivery companies are tenants with their own portal	Riders are Atavishaala users managed from the admin portal	Employing riders makes Atavishaala a logistics company with payroll, insurance and liability. Tenanted the fleet keeps that boundary where the law already puts it, and it is the only way to add delivery capacity without hiring.
D3	The order status is derived from shipments by a pure function	Keep the status column and update it alongside the shipments	Two sources of truth for one fact. Within a quarter they disagree on some edge case, and the disagreement is discovered by a customer. Deriving it costs one function and a table test; keeping both costs a permanent class of bug.
D4	Broadcast offers with first accept winning	A scoring model that assigns the best fleet	Scoring needs acceptance rates, transit times and failure rates that do not exist yet. Broadcast needs nothing and generates exactly those inputs. Revisit in Phase 2 with data.
D5	Last four characters only, no reveal, no permission for plaintext	A pii.read.raw permission granted to a small number of senior staff	A reveal path that exists will be used, then relied upon, then required. Its absence is what makes the encryption meaningful. The narrow, logged, time-boxed manifest release covers the one case that genuinely needs an address.
D6	The Advisor console lives inside the admin portal, role-gated	A fourth portal for agronomists	Agronomists are employees on the staff identity table with a staff token. A fourth deployment for three screens would add a repository, a hostname and a pipeline to save nothing.
D7	Mobile web for the fleet portal, no native rider app	A React Native rider app sharing code with the customer app	A native app adds store review cycles, a release train and a second mobile surface for one engineer we do not have. Mobile web covers the rider flow, and store billing rules would complicate a fleet-facing app anyway.
D8	Postgres job_queue with FOR UPDATE SKIP LOCKED, driven by scheduled jobs	A managed queue such as Cloud Tasks or Pub/Sub	The existing queue already works, costs nothing, and is visible in the same database as the rows it acts on. Adding a managed queue would add a service, a credential and a failure mode to solve a throughput problem we do not have.

0.16 WHAT DONE LOOKS LIKE

The twenty statements that decide whether this shipped

Definition of done is not a feeling at the end of week ten. It is these twenty statements, each either true with evidence attached or not true. In week nine every one is walked and marked met, partially met or not met, and every partially met item becomes either a week ten task or a written exception naming who accepted it.

ID	STATEMENT
D-01	A staff user can sign in with email, password and TOTP, and cannot sign in without TOTP.
D-02	Effective permissions resolve with DENY winning, and the resolution is unit-tested against a matrix.
D-03	Every mutating admin request appears in the audit log with a before/after diff.
D-04	No screen in any portal renders more than the last four characters of a masked field.
D-05	A product company can be invited, submit seven KYC documents, be verified and go ACTIVE.
D-06	A partner-drafted product passes moderation and appears in the mobile app catalog.
D-07	A multi-supplier order splits into shipments, and the app tracker shows a correct derived status.
D-08	A supplier can accept, pack, declare a shortfall, mark ready and hand over.
D-09	A delivery company can onboard, define service areas with a rate card, and add riders.
D-10	An offer broadcasts, expires, escalates through three waves and lands on the admin board.
D-11	A rider opens the manifest, the disclosure is registered, and delivery completes with OTP inside 200 m.
D-12	Three failed attempts force RTO automatically and the customer is refunded on RTO_DELIVERED.
D-13	A weekly payout run assembles, locks, releases with a UTR, and reconciles to the paisa.
D-14	A COD period is declared by a fleet and reconciled by finance, with variance computed.
D-15	A return with photo evidence is approved, picked, received by the supplier and refunded, with a compensating ledger entry.
D-16	An agronomist claims an advisory request from the admin portal and records a callback within the SLA.
D-17	All twelve CI gates pass on all five repositories.
D-18	M1..M8 apply cleanly to a restored production snapshot and the derived-status diff is zero rows.
D-19	The monthly bill is ₹67 and the eight free-tier alert thresholds are configured and firing on test.
D-20	Eleven runbooks are written and each has been rehearsed once by someone other than its author.

0.17 HOW TO DISAGREE WITH THIS DOCUMENT

The escalation path for an architectural objection

This charter is a set of decisions made at one point in time with incomplete information. Some of them are wrong. The useful question is not whether a decision is perfect but whether the objection is strong enough to pay the cost of changing it, and that question deserves a process rather than a corridor conversation.

If you think an invariant is wrong, write the objection as a paragraph naming the invariant, the cost it is imposing, and what you would put in its place. Bring it to the Wednesday blocker sync. If it is accepted, the fact base changes, all thirteen documents regenerate, and the decision log gains a row. If it is not accepted, the objection is recorded anyway, because the second person to raise it should be able to see that it was already considered and on what grounds.

What you must not do is work around an invariant quietly. A worked-around invariant is worse than a removed one, because the code no longer matches the document and nobody knows which to trust.

CHANGES THAT NEED ONLY A FACT-BASE PATCH

Counts, prices, names, endpoint additions, screen additions, task detail, week themes, risk wording, runbook steps. Patch `aa_facts.py`, regenerate, commit both the module and the PDFs.

CHANGES THAT NEED THIS DOCUMENT REWRITTEN

Anything touching the fourteen invariants, the namespace model, the tenancy mechanism, the shipment split, the money discipline, the PII posture, or the repository topology. These are load-bearing and their blast radius is the whole set.

READ NEXT

If you are an engineer, read AA-11 for your week and AA-02 before you write a line of backend code. If you are deciding scope or sequence, read AA-10. If you have fifteen minutes, read AA-12 and stop.